ONE-PAGE BRIEF

# Post-quantum cryptography review: zcash-android-wallet-sdk @ a95780ac00e0

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/zcash-android-wallet-sdk, commit `a95780ac00e0` · Reviewed: 2026-11-06 14:12 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
**Level 0 of 4**
no post-quantum cryptography

FINDINGS
**0** Critical **0** High **6** Medium
**20** Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

**Next step:** Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

## WHAT MATTERS MOST

| | |
|---|---|
| Medium<br>QSI-2026-19113 | **Quantum-vulnerable RSA key (2048-bit) in responsible_disclosure.md**<br>What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it.. |
| Medium<br>QSI-2026-19111 | **SHA-1 used in backend-lib/src/main/java/cash/z/ecc/android/sdk/internal/ext/FileExt.kt**<br>confirmed by the analyst<br>What to do: Replace with SHA-256/SHA-3 (or Argon2/bcrypt for passwords) where security-relevant. |
| Medium<br>QSI-2026-19112 | **Quantum-vulnerable RedDSA: authentication and identity (certificates, tokens, device attestation)...**<br>preliminary<br>What to do: Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them. |
| Medium<br>QSI-2026-19120 | **rsa 0.9.10 is affected by RUSTSEC-2023-0071 (CVE-2023-49092)**<br>What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations). |

22 more in the full report.

## WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

| Role | Algorithms | What to do |
|---|---|---|
| Medium authentication and identity (certificates, tokens, device attestation) | RedDSA | Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them |

## KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 24; unlikely to apply to this build: 16 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 8.

Analyst review: 1 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-23)

Static review of source code and manifests; files analysed: 350. No requests were sent to the owner's systems.

Full report, content SHA-256: `6bb7c7be5d230a735167a08277218fe10d891f442a4312e64e8d08655ab1c43d`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.